

Include

Relatório de Invasão: Include

Resumo

Objetivo: Explorar a aplicação web Include

Cadeia de ataque completa:

Loguei como usuário guest e fui em editar seu perfil , executei mudança de isAdmin false para true através de modificação insegura de propriedade do objeto e assim virei admin. Como admin eu acessei um path que mostrava duas rotas de api , sendo uma delas a rota que devolvia os admins e suas senhas porém era localhost.

Com isso achei uma rota settings que permitia SSRF e assim coloquei a rota que devolvia as infos dos admins e recuperei nomes e senhas. A partir disso descobri uma aplicação chamada sysmon mas ela não estava dentro das portas 1 a 10000 , com isso procurei ver se essa aplicação estava rodando em uma porta mais alta , fiz usando ffuf através da rota de settings fazendo busca em localhost que consegue ser mais rápido que buscas com nmap para um ip externo.

Nisso eu descobri a aplicação sysmon rodando na porta 50000 e nela explorei uma falha de LFI na rota de ver a imagem do perfil , bypassei o filtro de path relativo e assim acessei arquivos dentro do servidor.

Mas para executar algo relevante tiver de fazer Log Poison no arquivo /var/log/auth.log colocando um payload como nome de usuário ao tentar logar via ssh . Com o payload injetado eu simplesmente reiniciei a página e ele foi executado, mostrando o arquivo escondido que recuperei o conteúdo executando o LFI.

Ferramentas & Scripts Utilizados

- nmap
 - ffuf
 - openssl
 - netcat
 - remina
 - burp
-

1. Reconhecimento & Mapeamento

Scan de Portas (Nmap)

≡ Output do Nmap -sS

```
(kali@kali)-[~]
$ sudo nmap -sS 10.65.156.83 -p1-10000
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 08:59 -0400
Nmap scan report for 10.65.156.83
Host is up (0.15s latency).
Not shown: 9993 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
110/tcp   open  pop3
143/tcp   open  imap
993/tcp   open  imaps
995/tcp   open  pop3s
4000/tcp  open  remoteanything
Nmap done: 1 IP address (1 host up) scanned in 59.89 seconds
```

≡ Output do Nmap com -sC e -sV

```
(kali@kali)-[~]
$ sudo nmap -sV -sC 10.65.156.83 -p1-10000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 09:01 -0400
Nmap scan report for 10.65.156.83
Host is up (0.15s latency).
Not shown: 9993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 de:a7:ab:9c:64:5f:9e:3b:aa:bc:95:2e:d7:2a:96:9f (RSA)
|   256 8c:f3:ee:fe:81:70:9e:9e:7c:90:b4:49:31:a4:4f:fe (ECDSA)
|_  256 cf:5a:b5:ee:5b:80:5b:9a:16:d8:8d:35:24:0f:ac:41 (ED25519)
25/tcp    open  smtp         Postfix smtpd
|_ ssl-cert: Subject: commonName=ip-10-10-31-82.eu-west-1.compute.internal
|_ Subject Alternative Name: DNS:ip-10-10-31-82.eu-west-1.compute.internal
|_ Not valid before: 2021-11-10T16:53:34
|_ Not valid after:  2031-11-08T16:53:34
|_ smtp-command: mail.filepath.lab, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
|_ ssl-date: TLS randomness does not represent time
110/tcp   open  pop3         Dovecot pop3d
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=ip-10-10-31-82.eu-west-1.compute.internal
|_ Subject Alternative Name: DNS:ip-10-10-31-82.eu-west-1.compute.internal
|_ Not valid before: 2021-11-10T16:53:34
|_ Not valid after:  2031-11-08T16:53:34
|_ pop3-capabilities: PIPELINING TOP RESP-CODES SASL STLS UIDL AUTH-RESP-CODE CAPA
143/tcp   open  imap         Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=ip-10-10-31-82.eu-west-1.compute.internal
|_ Subject Alternative Name: DNS:ip-10-10-31-82.eu-west-1.compute.internal
|_ Not valid before: 2021-11-10T16:53:34
|_ Not valid after:  2031-11-08T16:53:34
|_ imap-capabilities: IMAP4rev1 OK more IDLE listed post-login have ENABLE SASL-IR LOGIN-REFERRALS Pre-login ID capabilities LITERAL+ START
LS
```

```
993/tcp   open  ssl/imap     Dovecot imapd (Ubuntu)
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=ip-10-10-31-82.eu-west-1.compute.internal
|_ Subject Alternative Name: DNS:ip-10-10-31-82.eu-west-1.compute.internal
|_ Not valid before: 2021-11-10T16:53:34
|_ Not valid after:  2031-11-08T16:53:34
|_ imap-capabilities: IMAP4rev1 AUTH-PLAIN more IDLE listed post-login have capabilities ENABLE OK SASL-IR Pre-login ID AUTH-LOGINA0001 LITERAL+ LOGIN-REFERRAL
S
995/tcp   open  ssl/pop3     Dovecot pop3d
|_ pop3-capabilities: PIPELINING TOP RESP-CODES SASL(PLAIN LOGIN) USER UIDL AUTH-RESP-CODE CAPA
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=ip-10-10-31-82.eu-west-1.compute.internal
|_ Subject Alternative Name: DNS:ip-10-10-31-82.eu-west-1.compute.internal
|_ Not valid before: 2021-11-10T16:53:34
|_ Not valid after:  2031-11-08T16:53:34
4000/tcp  open  http         Node.js (Express middleware)
|_ http-title: Sign In
Service Info: Host: mail.filepath.lab; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 87.51 seconds
```

Análise do Reconhecimento

Aqui vemos que temos um servidor web rodando na porta 4000 utilizando nodejs com express, o domínio é filepath.lab . Temos imap e pop3 rodando em outras portas , com suas versões normais e com TLS. Além disso temos um servidor ssh rodando na porta 22.

IMAP & POP3

```
(kali㉿kali)-[~]
$ nc -nv 10.65.156.83 110
(UNKNOWN) [10.65.156.83] 110 (pop3) open
+OK Dovecot (Ubuntu) ready.
capa
+OK
CAPA
TOP
UIDL
RESP-CODES
PIPELINING
AUTH-RESP-CODE
STLS
SASL
.
AUTH anonymous
-ERR [AUTH] Authentication failed.
USER guest
-ERR [AUTH] Plaintext authentication disallowed on non-secure (SSL/TLS) connections.
^C

(kali㉿kali)-[~]
$ nc -nv 10.65.156.83 143
(UNKNOWN) [10.65.156.83] 143 (imap2) open
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ STARTTLS LOGINDISABLED] Dovecot (Ubuntu) ready.
a1 capability
* CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ STARTTLS LOGINDISABLED
a1 OK Pre-login capabilities listed, post-login capabilities have more.
█
```

IMAPS & POP3S

IMAPS

```
read R BLOCK
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ AUTH=PLAIN AUTH=LOGIN] Dovecot (Ubuntu) ready.
1 LOGIN guest guest
1 NO [AUTHENTICATIONFAILED] Authentication failed.
1 LOGIN guest password
1 NO [AUTHENTICATIONFAILED] Authentication failed.
^C
```

POP3S

```
USER guest
+OK
PASS guest
-ERR [AUTH] Authentication failed.
USER guest
+OK
PASS guest
-ERR [AUTH] Authentication failed.
█
```

Foi visto que esses serviços não permitem login com o mesmo user da aplicação web (guest) e nem como anônimo. Irei explorar a aplicação web e voltar a esses serviços se caso não achar nada que eu explorar lá.

2. Enumeração Web & VHOSTs

```
ffuf -u http://10.65.156.83:4000/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .js,.txt,.js.bak,.md -fs 1295
```

```
ffuf -u http://10.65.156.83:4000/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .js,.txt,.js.bak,.md -fs 1295
```



v2.1.0-dev

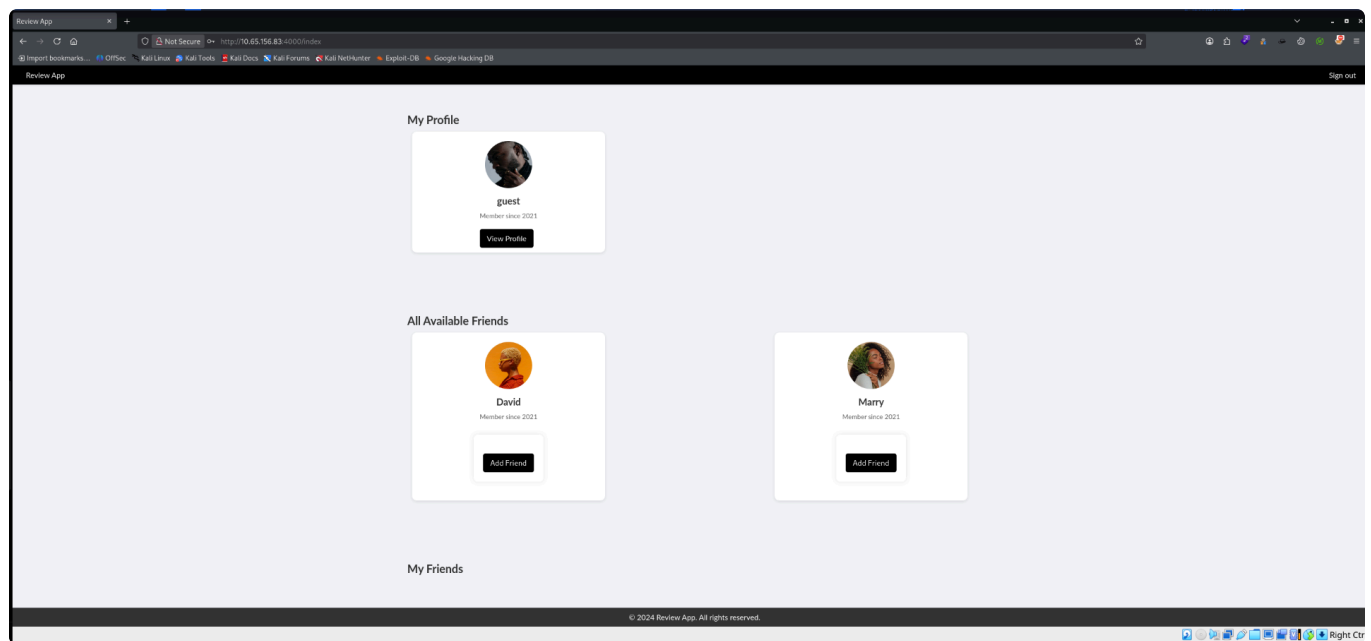
```
:: Method      : GET
:: URL         : http://10.65.156.83:4000/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Extensions : .js .txt .js.bak .md
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 100
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1295
```

index	[Status: 302, Size: 29, Words: 4, Lines: 1, Duration: 198ms]
images	[Status: 301, Size: 179, Words: 7, Lines: 11, Duration: 220ms]
signup	[Status: 500, Size: 1246, Words: 55, Lines: 11, Duration: 144ms]
Index	[Status: 302, Size: 29, Words: 4, Lines: 1, Duration: 146ms]
fonts	[Status: 301, Size: 177, Words: 7, Lines: 11, Duration: 144ms]
INDEX	[Status: 302, Size: 29, Words: 4, Lines: 1, Duration: 145ms]
Signup	[Status: 500, Size: 1246, Words: 55, Lines: 11, Duration: 145ms]
SignUp	[Status: 500, Size: 1246, Words: 55, Lines: 11, Duration: 145ms]
signUp	[Status: 500, Size: 1246, Words: 55, Lines: 11, Duration: 144ms]

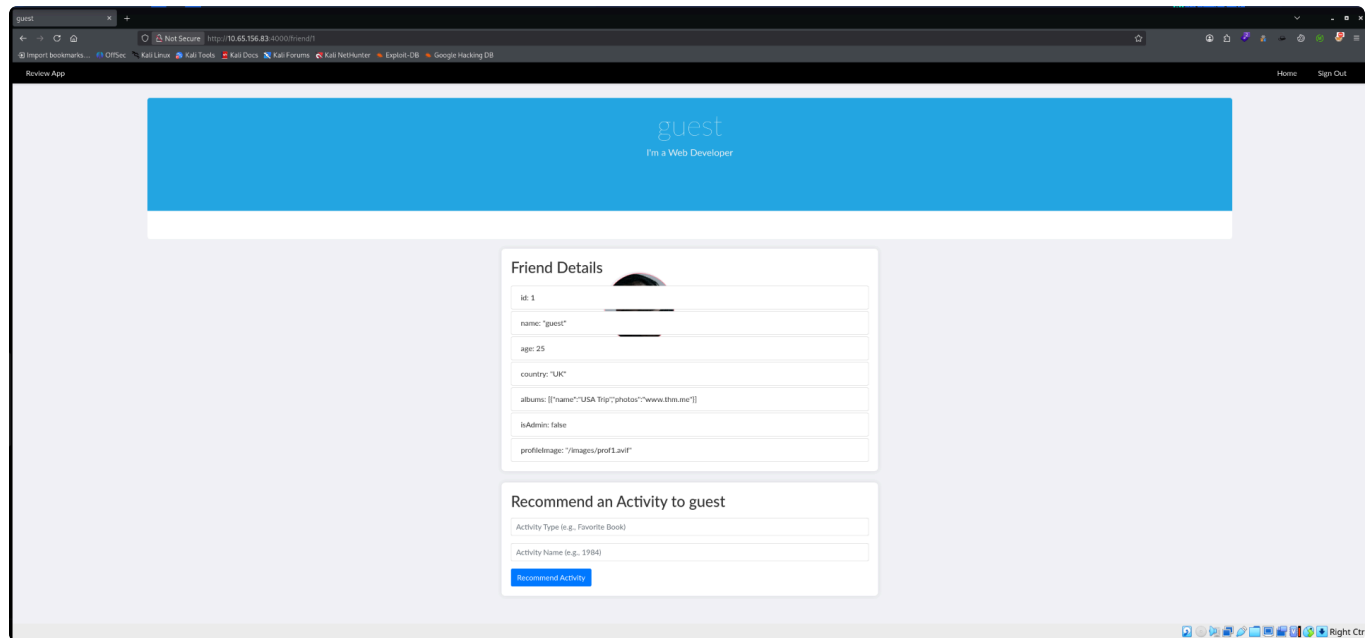
Dados e reconhecimento

Encontramos uma rota que chama profile.php que o query param ?img= permite LFI e com isso o utilizamos para encadear um ataque de log poisoning com RCE.

Index



friend/id



FFUF na rota de /admin/settings para enumerar portas

```
$ ffuf -request request.txt -request-proto http -w pin.txt -fs 30

v2.1.0-dev

:: Method      : POST
:: URL         : http://filepath.lab:4000/update-banner-image
:: Wordlist    : FUZZ: /media/sf_pastaCompartilhadaVmKali/txtsuteis/pin.txt
:: Header     : Referer: http://filepath.lab:4000/admin/settings
:: Header     : Upgrade-Insecure-Requests: 1
:: Header     : Priority: u=0, i
:: Header     : Host: filepath.lab:4000
:: Header     : User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
:: Header     : Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
:: Header     : Accept-Encoding: gzip, deflate, br
:: Header     : Origin: http://filepath.lab:4000
:: Header     : DNT: 1
:: Header     : Connection: keep-alive
:: Header     : Cookie: connect.sid=s%3Axm0Kmsr3A9m658dTzfmsY30ppd-enrR.Ww%28qY%2BEZf1340Qh8Rn61Fkok1EY9qDt7yXkq2uAl7%2Bg
:: Header     : Accept-Language: en-US,en;q=0.5
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Header     : Sec-GPC: 1
:: Data       : url=http://127.0.0.1:FUZZ/
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 30

4000 [Status: 302, Size: 74, Words: 5, Lines: 1, Duration: 149ms]
50000 [Status: 302, Size: 74, Words: 5, Lines: 1, Duration: 154ms]
```

Enumeração Sysmon como administrador

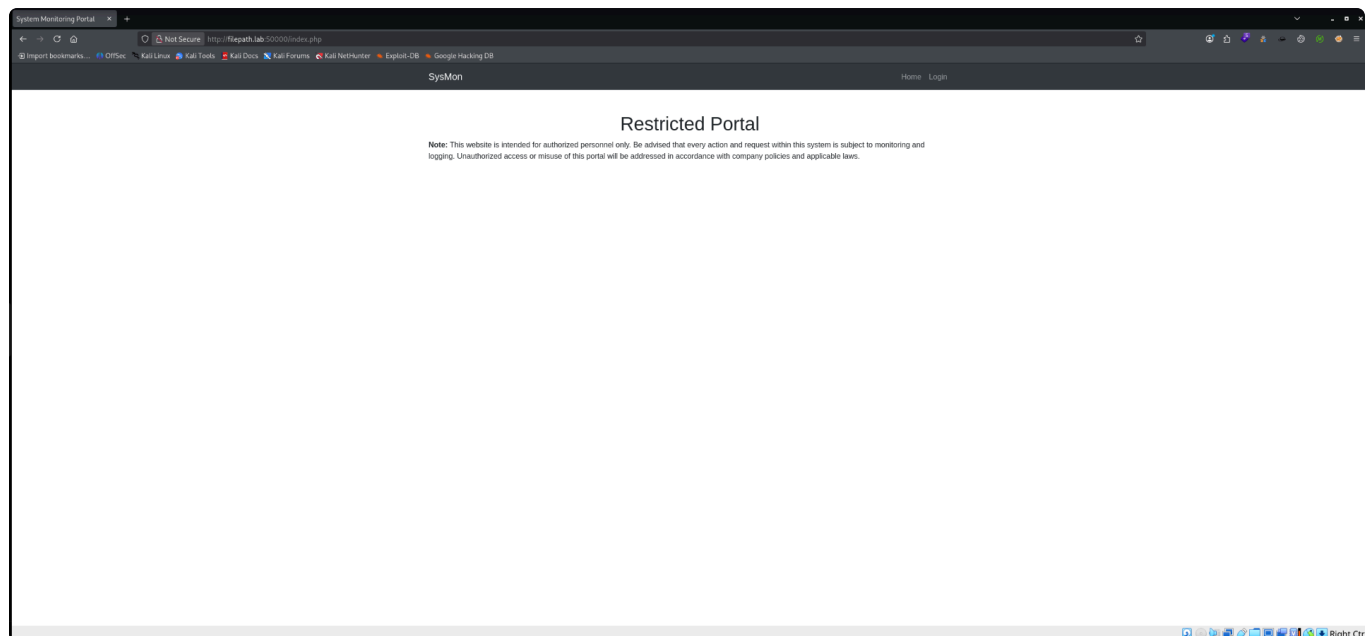
```
(kali@kali)~/media/sf_pastaCompartilhadaVmKali/txtsuteis$ ffuf -u http://filepath.lab:50000/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100 -e .php,.php.bak,.txt,.md -b "PHPSESSID=3312c143hfsaie11818a2b13gd" -fs 1613

v2.1.0-dev

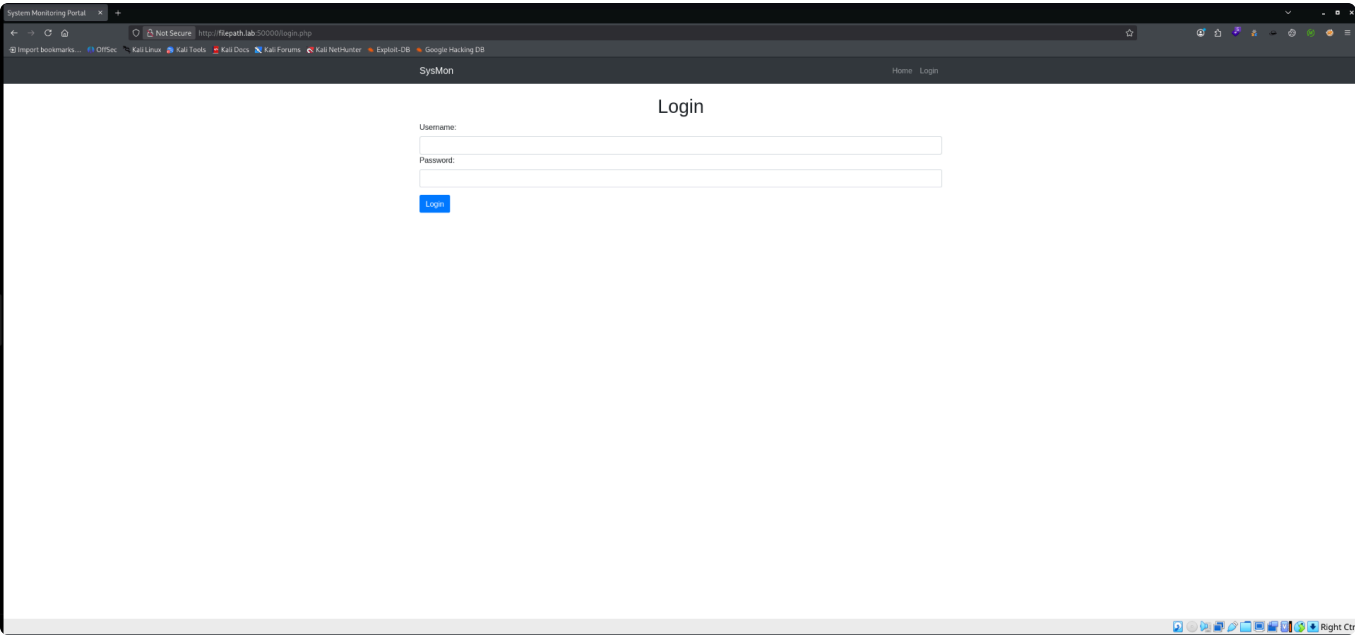
:: Method      : GET
:: URL         : http://filepath.lab:50000/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Header     : Cookie: PHPSESSID=3312c143hfsaie11818a2b13gd
:: Extensions : .php .php.bak .txt .md
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 100
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1613

login.php [Status: 200, Size: 2046, Words: 338, Lines: 48, Duration: 144ms]
templates [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 144ms]
profile.php [Status: 200, Size: 17, Words: 3, Lines: 1, Duration: 143ms]
uploads [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 146ms]
.php [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4267ms]
api.php [Status: 500, Size: 0, Words: 1, Lines: 1, Duration: 147ms]
javascript [Status: 301, Size: 326, Words: 20, Lines: 10, Duration: 145ms]
logout.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 146ms]
auth.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 155ms]
dashboard.php [Status: 302, Size: 1225, Words: 201, Lines: 28, Duration: 146ms]
```

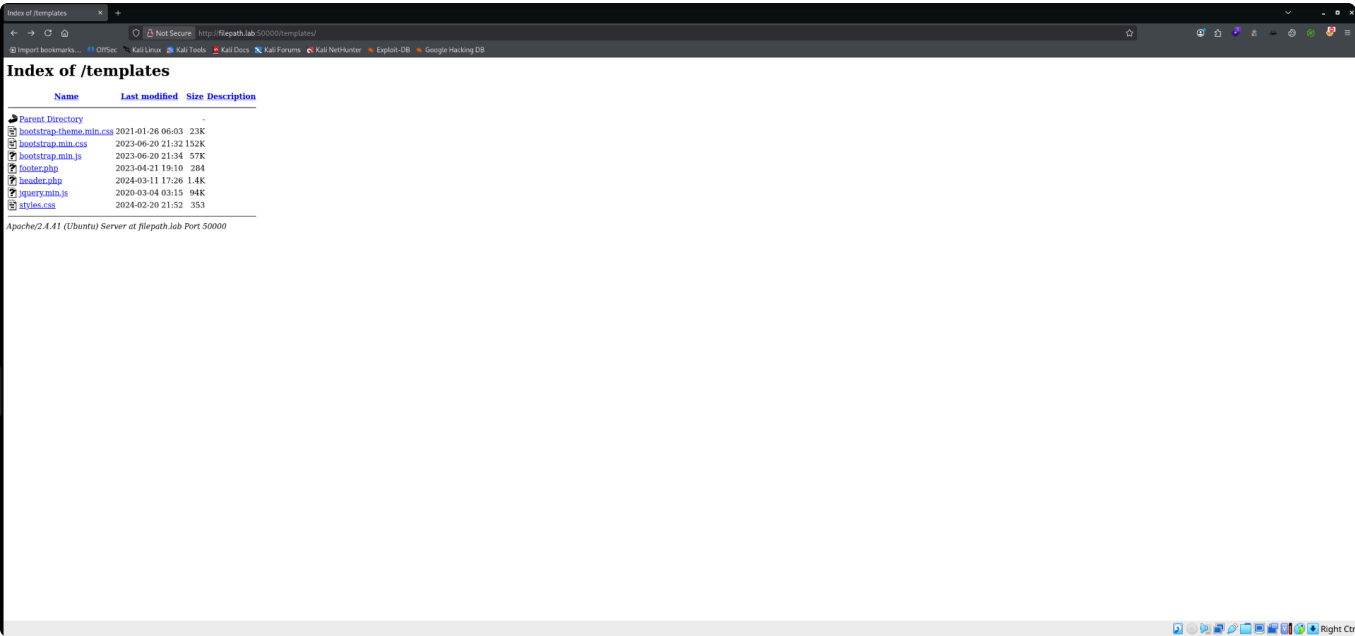
index.php



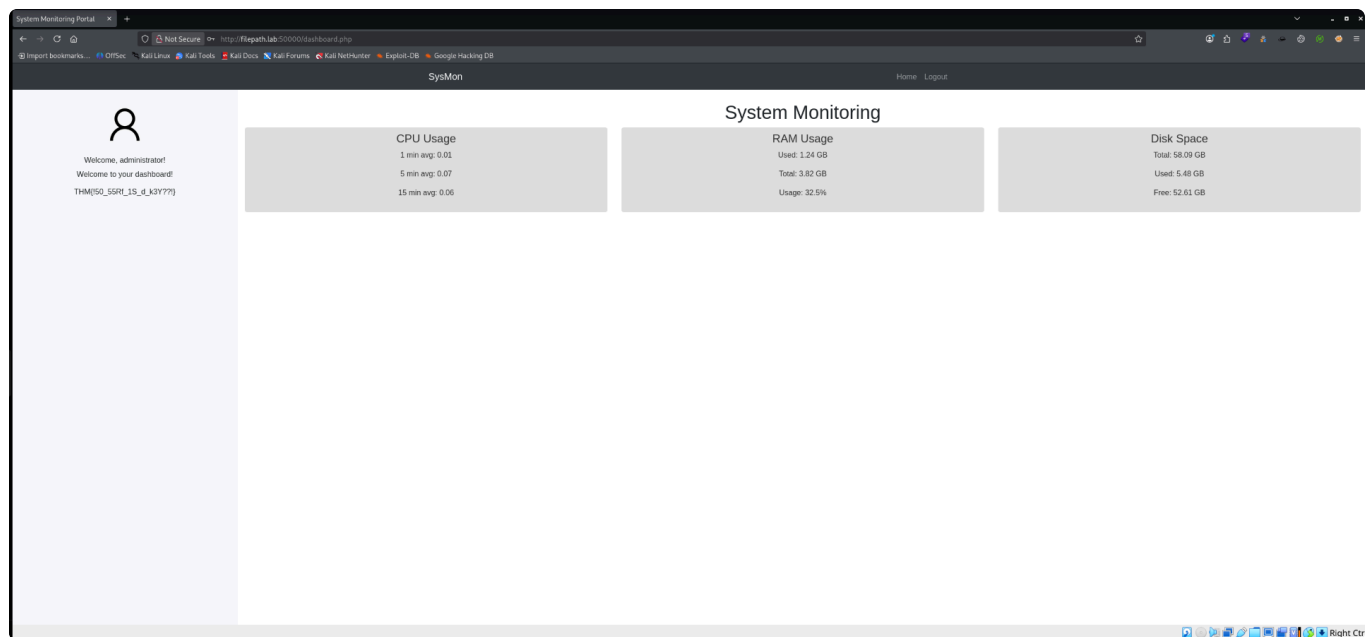
login.php



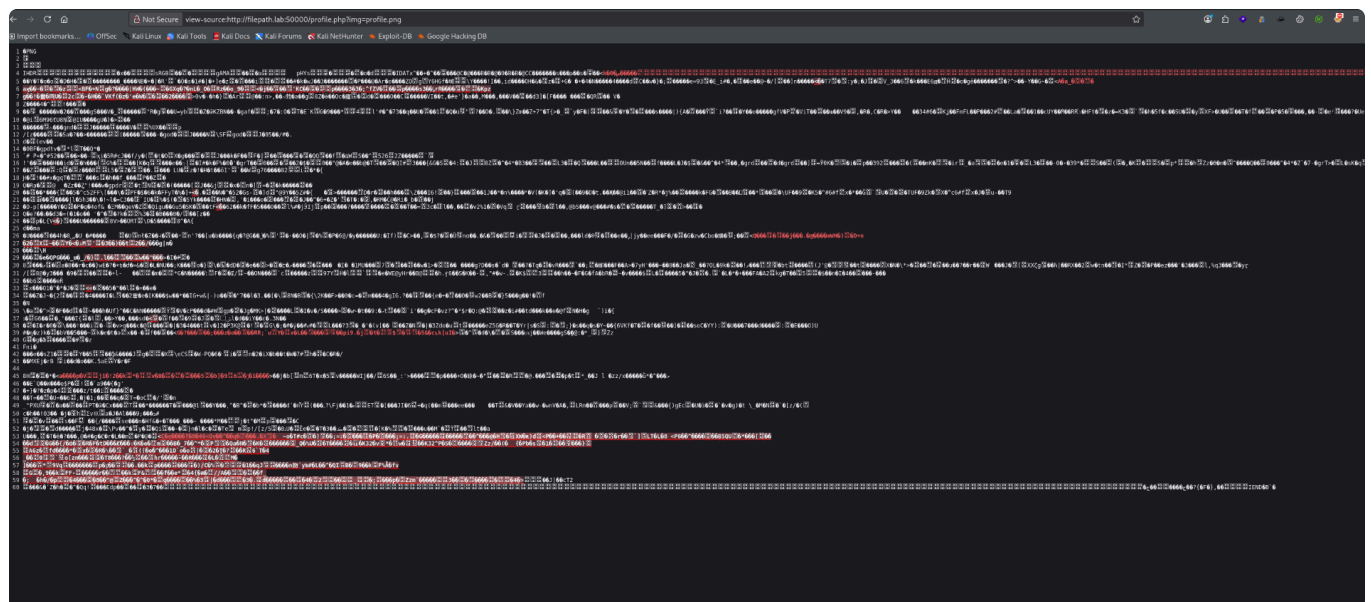
templates



dashboard.php



profile.php



⚡ 3. Exploração & Acesso Inicial (Foothold)

✖ Vulnerabilidade encontrada

Título: Modificação de propriedade de forma insegura

Risk Rating: 10 DREAD

Resumo: Na tela /friend/1 vemos o perfil do guest que é nosso usuário e vemos as propriedades do objeto dele , o isAdmin pode ser trocado de false para true através do

formulário de recomenda atividade pro guest, permitindo que viremos admin.

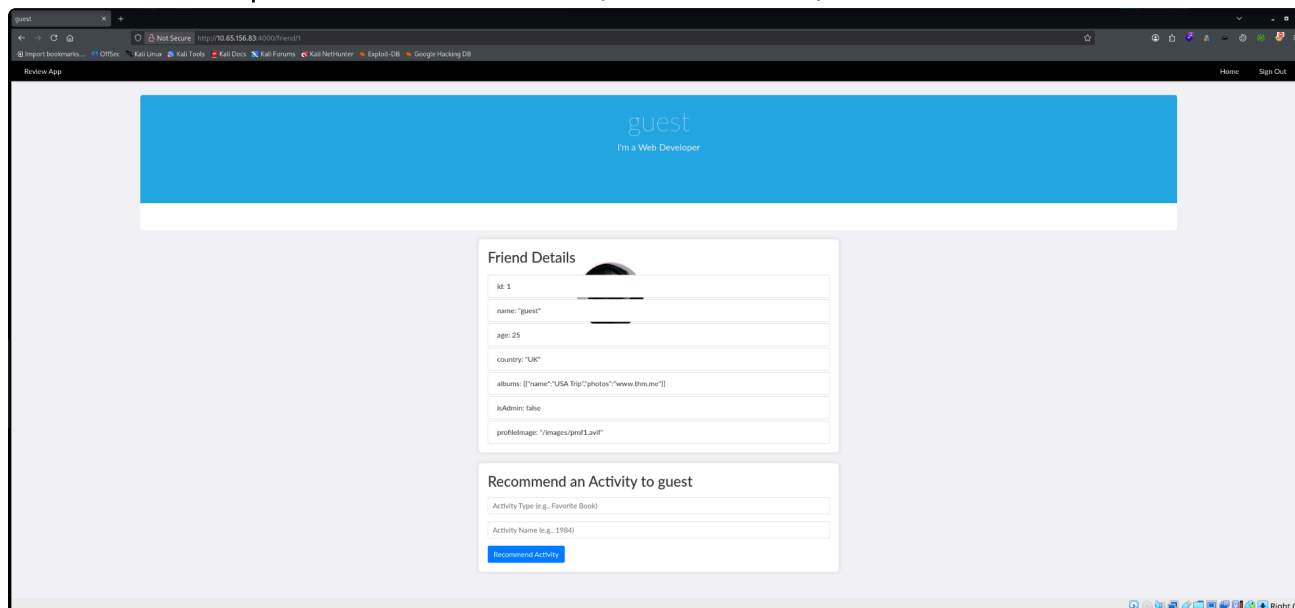
Background(Contexto adicional): Essa vulnerabilidade parte do fato de que podemos alterar um valor já existente em um objeto de usuário de forma não intencional já que não deveria ser possível fazer isso.

Impacto: Podemos como qualquer usuário virar admin e obter suas funcionalidades .

Conselhos e Remediações: Deve se filtrar a entrada do usuário e não permitir que ela modifique valores já existentes do objeto , essa funcionalidade de recomendar tarefas deve ser restrita a adicionar novos valores de tarefas na qual isAdmin deveria ser impedido de ser validado como uma entrada legítima , além de que a propriedade isAdmin não deveria ser visível nas informações dos objetos dos usuários.

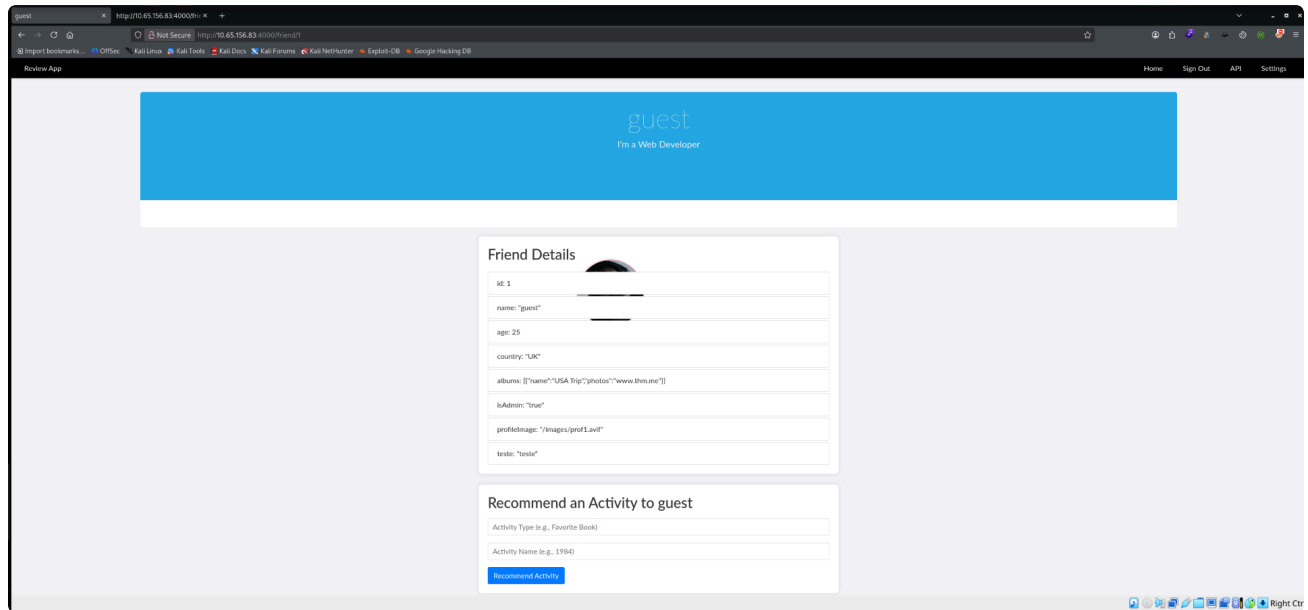
Detalhes Técnicos e Evidências:

1. Primeiro vamos para a tela de /friend/1 (nosso usuário)



2. Em recomenda atividade colocamos isAdmin no tipo da atividade e no valor colocamos true, apertando em recomendar atividade viramos admin

automaticamente.



✗ Vulnerabilidade encontrada

Título: SSRF

Risk Rating: 10 DREAD

Resumo: Podemos fazer o servidor buscar informações da api sobre todos os admins e suas senhas a partir de /admin/api ao coletar as urls de get Admins API e indo em /admin/settings que possui uma entrada que a gente coloca uma url para dar update no banner image , mas ao colocar as url's que coletamos essa rota nos devolve valores em base64 do resultado do get.

Background(Contexto adicional): SSRF é a capacidade de você usar uma funcionalidade de uma aplicação para induzir ela a fazer requisições a recursos internos do servidor alvo , permitindo que enumeremos recursos , rotas , exfiltremos dados e demais coisas.

Impacto: Conseguimos coletar os nomes de admins e senhas da aplicação , assim podemos logar como eles e utilizar de suas funcionalidades.

Conselhos e Remediações: Essa rota deve possuir um filtro para não permitir qualquer busca interna ao servidor filtrando url que contenham 127.0.0.1 , 127.1 ou qualquer derivação que comece com 127. , localhost ::1 e o que seja considerado localhost. Além disso deve ser filtrado buscas feitas para o ip público do servidor , o 127. somente não consegue restringir 100% e também restringir buscas a ips privados da rede .

Detalhes Técnicos e Evidências:

1. A gente acessa a rota /admin/api e visualizamos as rotas que podemos exfiltrar dados.

4. Conseguimos os nomes de usuários admin e suas senhas.

× Vulnerabilidade encontrada

Título: Remote code execution via LFI e Log Poisoning

Risk Rating: 10 DREAD

Resumo: É possível fazer execução de código de forma remota via poison feito no arquivo `/var/log/auth.log` e usando LFI na rota `/profile.php?img=` para depois ver o resultado do poison.

Background(Contexto adicional): Remote code execution é a capacidade de conseguirmos executar código dentro do servidor , LFI é podermos bypassar caminhos relativos ou absolutos e conseguir visualizar outros arquivos que não deveríamos conseguir ver e LogPoisoning é injetar payloads em arquivos de log que junto de um LFI causa RCE.

Impacto: Podemos conseguir executar comandos como `www-data` , exfiltrar dados e atrapalhar o funcionamento do servidor web.

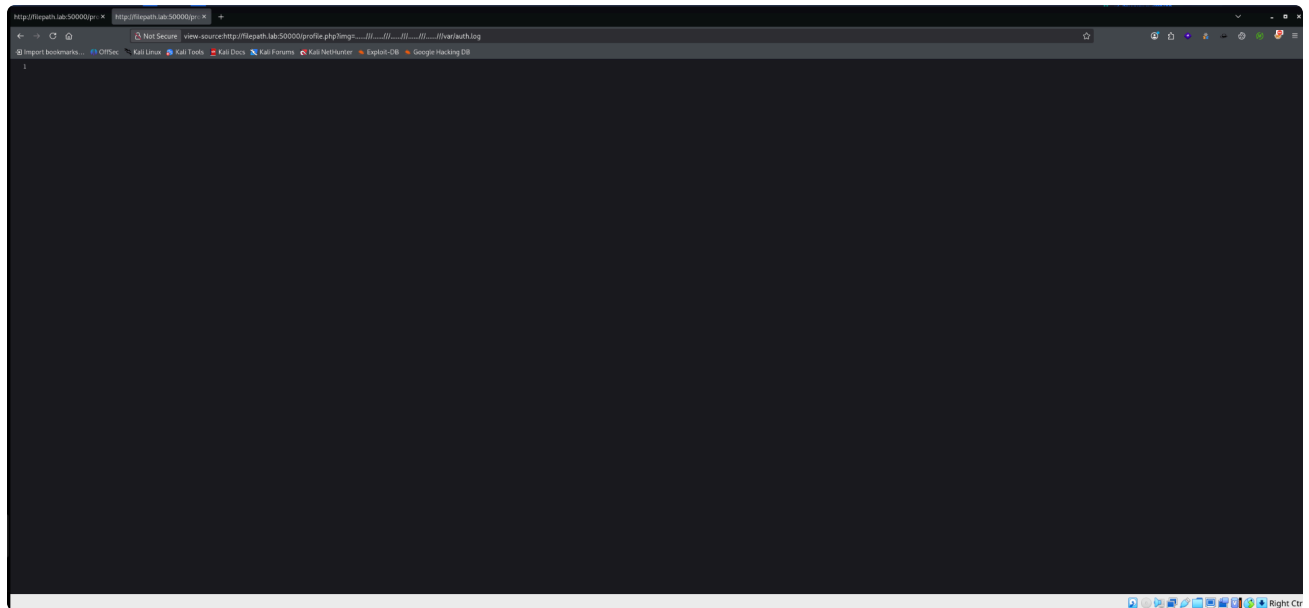
Conselhos e Remediações: Deve se fazer filtros que executam dentro de um loop para buscar todos os ./ , pois ./ e// não funcionam mas// funciona , visto que não foi feito de forma dinâmica esse filtro. Além disso deve se fazer verificações quanto a . e / com seus valores codificados e com dupla codificação , também feito de forma dinâmica para não permitir tripla e nem quádrupla codificação.

Detalhes Técnicos e Evidências:

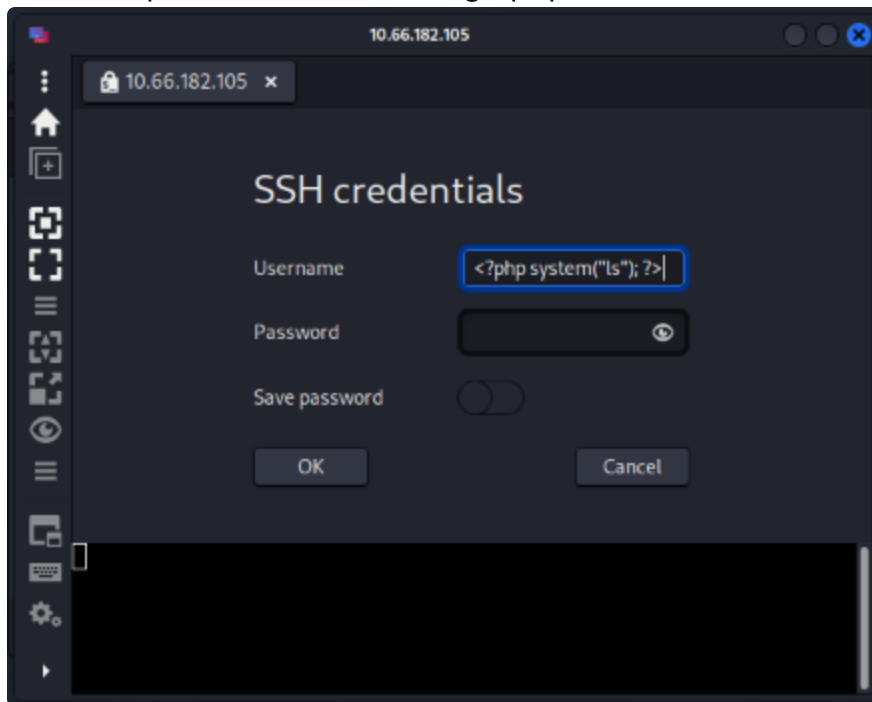
1. Vemos aqui a rota que permite LFI que bypasssei o caminho relativo com// , assim permitindo que eu voltasse diretórios e podemos ver conteúdos como passwd.

[illegible]

2. Olhamos /var/log/auth.log



3. Está vazio mas iremos agora popular esse arquivo com nosso payload. Iremos usar o remmina para colocar um código php no nome de usuário .



4. Enviamos sem senha mesmo , agora iremos olhar o auth.log denovo.

[illegible]

5. Vemos aqui que o ls foi executado corretamente, agora podemos pegar o valor do arquivo escondido.

view-source: http://f00p4th.lab-500003/profile.php?img=.../1801365e0f180f12853b48055e179123ee7

Import bookmarks...

1801365e0f180f12853b48055e179123ee7

Tabela de Credenciais Capturadas

Serviço / Local	Usuário	Senha / Hash	Origem do Achado
-----	-----	superSecretKey123	/admin/api, texto puro
ReviewAppUsername	admin	admin@!!!	http://127.0.0.1:5000/getAllAdm
SysMonAppUsername	administrator	S9qk6d#**LQU	http://127.0.0.1:5000/getAllAdm



Considerações Técnicas & Cheat Sheet

📘 Lições Aprendidas

1. Verificar se o user web tem permissão para ver os logs em /var/log , pois assim podemos executar log poisoning e executar se tiver LFI na aplicação.
 1. Arquivos de log importantes → /var/log/auth.log , /var/log/apache2/access.log ou error.log
2. Sempre enumerar o máximo possível , exploração boa vem de uma enumeração boa e eficiente.